개인정보의 안전성 확보조치 기준

[시행 2026. 7. 1.] [개인정보보호위원회고시 제2026-9호, 2026. 7. 1., 일부개정]

제1장 총칙
제1조(목적)
제2조(정의)
제2장 개인정보의 안전성 확보조치
제3조(안전조치의 적용 원칙)
제4조(내부 관리계획의 수립・시행 및 점검)
제5조(접근 권한의 관리)
제6조(접근통제)
제6조의2(인터넷망의 차단 조치 등)
제7조(개인정보의 암호화)
제8조(접속기록의 보관 및 점검)
제9조(악성프로그램 등 방지)
제10조(물리적 안전조치)
제11조(재해・재난 대비 안전조치)
제12조(출력・복사시 안전조치)
제13조(개인정보의 파기)
제3장 공공시스템 운영기관 등의 개인정보 안전성 확보조치
제14조(공공시스템운영기관의 안전조치 기준 적용)
제15조(공공시스템운영기관의 내부 관리계획의 수립・시행)
제16조(공공시스템운영기관의 접근 권한의 관리)
제17조(공공시스템운영기관의 접속기록의 보관 및 점검)
제18조(공공시스템운영기관의 취약점 점검 및 조치)
제19조(재검토 기한)

개인정보의 안전성 확보조치 기준

[시행 2026. 7. 1.] [개인정보보호위원회고시 제2026-9호, 2026. 7. 1., 일부개정]

개인정보보호위원회(신기술개인정보과), 02-2100-3067

제1장 총칙

제1조(목적) 이 기준은「개인정보 보호법」(이하 "법"이라 한다) 제29조와 같은 법 시행령(이하 "영"이라 한다) 제16조제2항, 제30조 및 제30조의2에 따라 개인정보처리자가 개인정보를 처리함에 있어서 개인정보가 분실・도난・유출・위조・변조 또는 훼손되지 아니하도록 안전성 확보에 필요한 기술적・관리적 및 물리적 안전조치에 관한 최소한의 기준을 정하는 것을 목적으로 한다.

제2조(정의) 이 기준에서 사용하는 용어의 뜻은 다음과 같다.

1. "개인정보처리시스템"이란 데이터베이스시스템 등 개인정보를 처리할 수 있도록 체계적으로 구성한 시스템을 말한다.
2. "이용자"란「정보통신망 이용촉진 및 정보보호 등에 관한 법률」제2조제1항제4호에 따른 정보통신서비스 제공자가 제공하는 정보통신서비스를 이용하는 자를 말한다.
3. "접속기록"이란 개인정보처리시스템에 접속하는 자가 개인정보처리시스템에 접속하여 수행한 업무내역에 대하여 식별자, 접속일시, 접속지 정보, 처리한 정보주체 정보, 수행업무 등을 전자적으로 기록한 것을 말한다. 이 경우 "접속"이란 개인정보처리시스템과 연결되어 데이터 송신 또는 수신이 가능한 상태를 말한다.
4. "정보통신망"이란「정보통신망 이용촉진 및 정보보호 등에 관한 법률」제2조제1항제1호의「전기통신사업법」제2조제2호에 따른 전기통신설비를 이용하거나 전기통신설비와 컴퓨터 및 컴퓨터의 이용기술을 활용하여 정보를 수집・가공・저장・검색・송신 또는 수신하는 정보통신체계를 말한다.
5. "P2P(Peer to Peer)"란 정보통신망을 통해 서버의 도움 없이 개인과 개인이 직접 연결되어 파일을 공유하는 것을 말한다.
6. "공유설정"이란 컴퓨터 소유자의 파일을 타인이 조회・변경・복사 등을 할 수 있도록 설정하는 것을 말한다.
7. "모바일 기기"란 무선망을 이용할 수 있는 스마트폰, 태블릿 컴퓨터 등 개인정보 처리에 이용되는 휴대용 기기를 말한다.
8. "비밀번호"란 정보주체 및 개인정보취급자 등이 개인정보처리시스템 또는 정보통신망을 관리하는 시스템 등에 접속할 때 식별자와 함께 입력하여 정당한 접속 권한을 가진 자라는 것을 인증할 수 있도록 시스템에 전달해야 하는 고유의 문자열로서 타인에게 공개되지 않는 정보를 말한다.
9. "생체정보"란 지문, 얼굴, 홍채, 정맥, 음성, 필적 등 개인의 신체적, 생리적, 행동적 특징에 관한 정보로서 특정 개인을 인증・식별하거나 개인에 관한 특징을 알아보기 위해 일정한 기술적 수단을 통해 처리되는 정보를 말한다.
10. "생체인식정보"란 생체정보 중 특정 개인을 인증 또는 식별할 목적으로 일정한 기술적 수단을 통해 처리되는 정보를 말한다.

11. "인증정보"란 개인정보처리시스템 또는 정보통신망을 관리하는 시스템 등에 접속을 요청하는 자의 신원을 검증하는데 사용되는 정보를 말한다.
12. "내부망"이란 인터넷망 차단, 접근 통제시스템 등에 의해 인터넷 구간에서의 접근이 통제 또는 차단되는 구간을 말한다.
13. "위험도 분석"이란 개인정보 유출에 영향을 미칠 수 있는 다양한 위험요소를 식별·평가하고 해당 위험요소를 적절하게 통제할 수 있는 방안 마련을 위한 종합적으로 분석하는 행위를 말한다.
14. "보조저장매체"란 이동형 하드디스크(HDD), 유에스비(USB)메모리 등 자료를 저장할 수 있는 매체로서 개인정보처리시스템 또는 개인용 컴퓨터 등과 쉽게 연결·분리할 수 있는 저장매체를 말한다.

제2장 개인정보의 안전성 확보조치

제3조(안전조치의 적용 원칙) 개인정보처리자는 처리하는 개인정보의 보유 수, 유형 및 정보주체에게 미치는 영향 등을 고려하여 스스로의 환경에 맞는 개인정보의 안전성 확보에 필요한 조치를 적용하여야 한다.

제4조(내부 관리계획의 수립·시행 및 점검) ① 개인정보처리자는 개인정보의 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 의사결정 절차를 통하여 다음 각 호의 사항을 포함하는 내부 관리계획을 수립·시행하여야 한다. 다만, 1만명 미만의 정보주체에 관하여 개인정보를 처리하는 소상공인·개인·단체의 경우에는 생략할 수 있다.

1. 개인정보 보호 조직의 구성 및 운영에 관한 사항
2. 개인정보 보호책임자의 자격요건 및 지정에 관한 사항
3. 개인정보 보호책임자와 개인정보취급자의 역할 및 책임에 관한 사항
4. 개인정보취급자에 대한 관리·감독 및 교육에 관한 사항
5. 접근 권한의 관리에 관한 사항
6. 접근통제에 관한 사항
7. 개인정보의 암호화 조치에 관한 사항
8. 접속기록 보관 및 점검에 관한 사항
9. 악성프로그램 등 방지에 관한 사항
10. 개인정보의 유출, 도난 방지 등을 위한 취약점 점검에 관한 사항
11. 물리적 안전조치에 관한 사항
12. 출력·복사시 안전조치에 관한 사항
13. 개인정보의 파기에 관한 사항
14. 개인정보 유출사고 대응 계획 수립·시행에 관한 사항
15. 위험 분석 및 관리에 관한 사항
16. 개인정보 처리업무를 위탁하는 경우 수탁자에 대한 관리 및 감독에 관한 사항
17. 개인정보 내부 관리계획의 수립, 변경 및 승인에 관한 사항
18. 그 밖에 개인정보 보호를 위하여 필요한 사항

② 개인정보처리자는 다음 각 호의 사항을 정하여 개인정보 보호책임자 및 개인정보취급자를 대상으로 사업규모, 개인정보 보유 수, 업무성격 등에 따라 차등화하여 필요한 교육을 정기적으로 실시하여야 한다.

1. 교육목적 및 대상
2. 교육 내용
3. 교육 일정 및 방법

③ 개인정보처리자는 제1항 각 호의 사항에 중요한 변경이 있는 경우에는 이를 즉시 반영하여 내부 관리계획을 수정하여 시행하고, 그 수정 이력을 관리하여야 한다.

④ 개인정보 보호책임자는 접근 권한 관리, 접속기록 보관 및 점검, 암호화 조치 등 내부 관리계획의 이행 실태를 연1회 이상 점검·관리 하여야 한다.

제5조(접근 권한의 관리) ① 개인정보처리자는 개인정보처리시스템에 대한 접근 권한을 업무 수행에 필요한 최소한의 범위로 차등 부여하여야 한다.

② 개인정보처리자는 개인정보취급자 또는 개인정보취급자의 업무가 변경되었을 경우 지체 없이 개인정보처리시스템의 접근 권한을 변경 또는 말소하여야 한다.

③ 개인정보처리자는 제1항 및 제2항에 의한 권한 부여, 변경 또는 말소에 대한 내역을 기록하고, 그 기록을 최소 3년간 보관하여야 한다.

④ 개인정보처리자는 개인정보처리시스템에 접근할 수 있는 계정을 발급하는 경우 정당한 사유가 없는 한 개인정보취급자 별로 계정을 발급하고 다른 개인정보취급자와 공유되지 않도록 하여야 한다.

⑤ 개인정보처리자는 개인정보취급자 또는 정보주체의 인증수단을 안전하게 적용하고 관리하여야 한다.

⑥ 개인정보처리자는 정당한 권한을 가진 자만이 개인정보처리시스템에 접근할 수 있도록 일정 횟수 이상 인증에 실패한 경우 개인정보처리시스템에 대한 접근을 제한하는 등 필요한 조치를 하여야 한다.

제6조(접근통제) ① 개인정보처리자는 정보통신망을 통한 불법적인 접근 및 침해사고 방지를 위해 다음 각 호의 안전조치를 하여야 한다.

1. 개인정보처리시스템에 대한 접속 권한을 인터넷 프로토콜(IP) 주소 등으로 제한하여 인가받지 않은 접근을 제한
2. 개인정보처리시스템에 접속한 인터넷 프로토콜(IP) 주소 등을 분석하여 개인정보 유출 시도 탐지 및 대응

② 개인정보처리자는 개인정보처리시스템에 대한 정당한 접근 권한을 가진 자(다만, 정보주체는 제외한다)가 정보통신망을 통해 외부에서 개인정보처리시스템에 접속하려는 경우 인증서, 보안토큰, 일회용 비밀번호 등 안전한 인증수단을 적용하여야 한다. 다만, 이용자가 아닌 정보주체의 개인정보를 처리하는 개인정보처리시스템의 경우 가상사설망 등 안전한 접속수단 또는 안전한 인증수단을 적용할 수 있다.

③ 개인정보처리자는 처리하는 개인정보가 인터넷 홈페이지, P2P, 공유설정 등을 통하여 권한이 없는 자에게 공개되거나 유출되지 않도록 개인정보처리시스템, 개인정보취급자의 컴퓨터 및 모바일 기기 등에 조치를 하여야 한다.

④ 개인정보처리자는 개인정보처리시스템에 대한 불법적인 접근 및 침해사고 방지를 위하여 개인정보취급자가 일정시간 이상 업무처리를 하지 않는 경우에는 자동으로 접속이 차단되도록 하는 등 필요한 조치를 하여야 한다.

⑤ 개인정보처리자는 업무용 모바일 기기의 분실・도난 등으로 개인정보가 유출되지 않도록 해당 모바일 기기에 비밀번호 설정 등의 보호조치를 하여야 한다.

⑥ 삭제

제6조의2(인터넷망의 차단 조치 등) ① 전년도 말 기준 직전 3개월간 그 개인정보가 저장・관리되고 있는 이용자 수가 일일평균 100만명 이상인 개인정보처리자는 다음 각 호의 어느 하나에 해당하는 개인정보취급자의 컴퓨터 등에 대해 인터넷망 차단 조치를 하여야 한다. 다만,「클라우드컴퓨팅 발전 및 이용자 보호에 관한 법률」제2조 제3호에 따른 클라우드컴퓨팅서비스를 이용하여 개인정보처리시스템을 구성・운영하는 경우에는 해당 서비스에 대한 접속 외에는 인터넷을 차단하는 조치를 하여야 한다.

1. 개인정보처리시스템에 대한 접근 권한을 설정할 수 있는 개인정보취급자
2. 개인정보처리시스템에서 개인정보를 다운로드 또는 파기할 수 있는 개인정보취급자

② 제1항제2호에도 불구하고 개인정보처리자는 내부 관리계획에서 정한 위험 분석 결과가 다음 각 호의 어느 하나에 해당하는 경우에는 제1항에 따른 인터넷망 차단 조치를 하지 아니할 수 있다. 다만, 법 제23조에 따른 민감정보 또는 제7조제1항・제2항에 따른 개인정보를 다운로드 또는 파기할 수 있는 개인정보취급자의 컴퓨터 등에 대해서는 그러하지 아니하다.

1. 위험 분석 결과 확인된 위험이 현저히 낮은 경우
2. 위험 분석 결과 확인된 위험을 감소시킬 수 있는 보호조치를 적용한 경우. 이 경우 개인정보처리자는 [별표]에 따른 예시를 고려하여야 한다.

제7조(개인정보의 암호화) ① 개인정보처리자는 비밀번호, 생체인식정보 등 인증정보를 저장 또는 정보통신망을 통하여 송・수신하는 경우에 이를 안전한 암호 알고리즘으로 암호화하여야 한다. 다만, 비밀번호를 저장하는 경우에는 복호화되지 아니하도록 일방향 암호화하여 저장하여야 한다.

② 개인정보처리자는 다음 각 호의 해당하는 이용자의 개인정보에 대해서는 안전한 암호 알고리즘으로 암호화하여 저장하여야 한다.

1. 주민등록번호
2. 여권번호
3. 운전면허번호
4. 외국인등록번호
5. 신용카드번호
6. 계좌번호
7. 생체인식정보

③ 개인정보처리자는 이용자가 아닌 정보주체의 개인정보를 다음 각 호와 같이 저장하는 경우에는 암호화하여야 한다.

1. 인터넷망 구간 및 인터넷망 구간과 내부망의 중간 지점(DMZ : Demilitarized Zone)에 고유식별정보를 저장하는 경우
2. 내부망에 고유식별정보를 저장하는 경우(다만, 주민등록번호 외의 고유식별정보를 저장하는 경우에는 다음 각 목의 기준에 따라 암호화의 적용여부 및 적용범위를 정하여 시행할 수 있다)

가. 법 제33조에 따른 개인정보 영향평가의 대상이 되는 공공기관의 경우에는 해당 개인정보 영향평가의 결과
나. 암호화 미적용시 위험도 분석에 따른 결과

④ 개인정보처리자는 개인정보를 정보통신망을 통하여 인터넷망 구간으로 송·수신하는 경우에는 이를 안전한 암호 알고리즘으로 암호화하여야 한다.

⑤ 개인정보처리자는 이용자의 개인정보 또는 이용자가 아닌 정보주체의 고유식별정보, 생체인식정보를 개인정보취급자의 컴퓨터, 모바일 기기 및 보조저장매체 등에 저장할 때에는 안전한 암호 알고리즘을 사용하여 암호화한 후 저장하여야 한다.

⑥ 10만명 이상의 정보주체에 관하여 개인정보를 처리하는 대기업·중견기업·공공기관 또는 100만명 이상의 정보주체에 관하여 개인정보를 처리하는 중소기업·단체에 해당하는 개인정보처리자는 암호화된 개인정보를 안전하게 보관하기 위하여 안전한 암호 키 생성, 이용, 보관, 배포 및 파기 등에 관한 절차를 수립·시행하여야 한다.

제8조(접속기록의 보관 및 점검) ① 개인정보처리자는 개인정보처리시스템에 접속한 자(다만, 정보주체는 제외한다)의 접속기록을 1년 이상 보관·관리하여야 한다. 다만, 다음 각 호의 어느 하나에 해당하는 경우에는 2년 이상 보관·관리하여야 한다.

1. 5만명 이상의 정보주체에 관한 개인정보를 처리하는 개인정보처리시스템에 해당하는 경우
2. 고유식별정보 또는 민감정보를 처리하는 개인정보처리시스템에 해당하는 경우
3. 개인정보처리자로서 「전기통신사업법」제6조제1항에 따라 등록을 하거나 같은 항 단서에 따라 신고한 기간통신사업자에 해당하는 경우

② 개인정보처리자는 개인정보의 오·남용, 분실·도난·유출·위조·변조 또는 훼손 등에 대응하기 위하여 개인정보취급자의 개인정보처리시스템에 대한 접속기록 및 개인정보 다운로드 상황을 확인하고 점검하는 주기·방법·사후조치절차 등을 내부 관리계획으로 정하고 이행하여야 한다.

③ 개인정보처리자는 접속기록이 위·변조 및 도난, 분실되지 않도록 해당 접속기록을 안전하게 보관하기 위한 조치를 하여야 한다.

제9조(악성프로그램 등 방지) ① 개인정보처리자는 악성프로그램 등을 방지·치료할 수 있는 보안 프로그램을 설치·운영하여야 하며, 다음 각 호의 사항을 준수하여야 한다.

1. 프로그램의 자동 업데이트 기능을 사용하거나, 정당한 사유가 없는 한 일 1회 이상 업데이트를 실시하는 등 최신의 상태로 유지
2. 발견된 악성프로그램 등에 대해 삭제 등 대응 조치

② 개인정보처리자는 악성프로그램 관련 경보가 발령된 경우 또는 사용 중인 응용 프로그램이나 운영체제 소프트웨어의 제작업체에서 보안 업데이트 공지가 있는 경우 정당한 사유가 없는 한 즉시 이에 따른 업데이트 등을 실시하여야 한다.

제10조(물리적 안전조치) ① 개인정보처리자는 전산실, 자료보관실 등 개인정보를 보관하고 있는 물리적 보관 장소를 별도로 두고 있는 경우에는 이에 대한 출입통제 절차를 수립·운영하여야 한다.

② 개인정보처리자는 개인정보가 포함된 서류, 보조저장매체 등을 잠금장치가 있는 안전한 장소에 보관하여야 한다.

③ 개인정보처리자는 개인정보가 포함된 보조저장매체의 반출・입 통제를 위한 보안대책을 마련하여야 한다. 다만, 별도의 개인정보처리시스템을 운영하지 아니하고 업무용 컴퓨터 또는 모바일 기기를 이용하여 개인정보를 처리하는 경우에는 이를 적용하지 아니할 수 있다.

제11조(재해・재난 대비 안전조치) 10만명 이상의 정보주체에 관하여 개인정보를 처리하는 대기업・중견기업・공공기관 또는 100만명 이상의 정보주체에 관하여 개인정보를 처리하는 중소기업・단체에 해당하는 개인정보처리자는 화재, 홍수, 단전 등의 재해・재난 발생 시 개인정보처리시스템 보호를 위한 다음 각 호의 조치를 하여야 한다.

1. 위기대응 매뉴얼 등 대응절차를 마련하고 정기적으로 점검
2. 개인정보처리시스템 백업 및 복구를 위한 계획을 마련

제12조(출력・복사시 안전조치) ① 개인정보처리자는 개인정보처리시스템에서 개인정보의 출력시(인쇄, 화면표시, 파일생성 등) 용도를 특정하여야 하며, 용도에 따라 출력 항목을 최소화하여야 한다.

② 개인정보처리자는 개인정보가 포함된 종이 인쇄물, 개인정보가 복사된 외부 저장매체 등 개인정보의 출력・복사물을 안전하게 관리하기 위해 필요한 안전조치를 하여야 한다.

제13조(개인정보의 파기) ① 개인정보처리자는 개인정보를 파기할 경우 다음 각 호 중 어느 하나의 조치를 하여야 한다.

1. 완전파괴(소각・파쇄 등)
2. 전용 소자장비(자기장을 이용해 저장장치의 데이터를 삭제하는 장비)를 이용하여 삭제
3. 데이터가 복원되지 않도록 초기화 또는 덮어쓰기 수행

② 개인정보처리자가 개인정보의 일부만을 파기하는 경우, 제1항의 방법으로 파기하는 것이 어려울 때에는 다음 각 호의 조치를 하여야 한다.

1. 전자적 파일 형태인 경우 : 개인정보를 삭제한 후 복구 및 재생되지 않도록 관리 및 감독
2. 제1호 외의 기록물, 인쇄물, 서면, 그 밖의 기록매체인 경우 : 해당 부분을 마스킹, 구멍 뚫기 등으로 삭제

③ 기술적 특성으로 제1항 및 제2항의 방법으로 파기하는 것이 현저히 곤란한 경우에는 법 제58조의2에 해당하는 정보로 처리하여 복원이 불가능하도록 조치를 하여야 한다.

제3장 공공시스템 운영기관 등의 개인정보 안전성 확보조치

제14조(공공시스템운영기관의 안전조치 기준 적용) ① 다음 각 호의 어느 하나에 해당하는 개인정보처리시스템 중에서 개인정보보호위원회(이하 "보호위원회"라 한다)가 지정하는 개인정보처리시스템(이하 "공공시스템"이라 한다)을 운영하는 공공기관(이하 "공공시스템운영기관"이라 한다)은 제2장의 개인정보의 안전성 확보 조치 외에 이 장의 조치를 하여야 한다.

1. 2개 이상 기관의 공통 또는 유사한 업무를 지원하기 위하여 단일 시스템을 구축하여 다른 기관이 접속하여 이용할 수 있도록 한 단일접속 시스템으로서 다음 각 목의 어느 하나에 해당하는 경우

   가. 100만명 이상의 정보주체에 관한 개인정보를 처리하는 시스템

나. 개인정보처리시스템에 대한 개인정보취급자의 수가 200명 이상인 시스템

다. 정보주체의 사생활을 현저히 침해할 우려가 있는 민감한 개인정보를 처리하는 시스템

2. 2개 이상 기관의 공통 또는 유사한 업무를 지원하기 위하여 표준이 되는 시스템을 개발하여 다른 기관이 운영할 수 있도록 배포한 표준배포 시스템으로서 대국민 서비스를 위한 행정업무 또는 민원업무 처리용으로 사용하는 경우

3. 기관의 고유한 업무 수행을 지원하기 위하여 기관별로 운영하는 개별 시스템으로서 다음 각 목의 어느 하나에 해당하는 경우

가. 100만명 이상의 정보주체에 관한 개인정보를 처리하는 시스템

나. 개인정보처리시스템에 대한 개인정보취급자의 수가 200명 이상인 시스템

다.「주민등록법」에 따른 주민등록정보시스템과 연계하여 운영되는 시스템

라. 총 사업비가 100억원 이상인 시스템

② 제1항에도 불구하고 보호위원회는 다음 각 호의 어느 하나에 해당하는 개인정보처리시스템에 대하여는 공공시스템으로 지정하지 않을 수 있다.

1. 체계적인 개인정보 검색이 어려운 경우

2. 내부적 업무처리만을 위하여 사용되는 경우

3. 그 밖에 개인정보가 유출될 가능성이 상대적으로 낮은 경우로서 보호위원회가 인정하는 경우

제15조(공공시스템운영기관의 내부 관리계획의 수립・시행) 공공시스템운영기관은 공공시스템 별로 다음 각 호의 사항을 포함하여 내부 관리계획을 수립・시행하여야 한다.

1. 영 제30조의2제4항에 따른 관리책임자(이하 "관리책임자"라 한다)의 지정에 관한 사항

2. 관리책임자의 역할 및 책임에 관한 사항

3. 제4조제1항제3호에 관한 사항 중 개인정보취급자의 역할 및 책임에 관한 사항

4. 제4조제1항제4호부터 제6호까지 및 제8호에 관한 사항

5. 제16조부터 제18조까지에 관한 사항

제16조(공공시스템운영기관의 접근 권한의 관리) ① 공공시스템운영기관은 공공시스템에 대한 접근 권한을 부여, 변경 또는 말소하려는 때에는 인사정보와 연계하여야 한다.

② 공공시스템운영기관은 인사정보에 등록되지 않은 자에게 제5조제4항에 따른 계정을 발급해서는 안된다. 다만, 긴급상황 등 불가피한 사유가 있는 경우에는 그러하지 아니하며, 그 사유를 제5조제3항에 따른 내역에 포함하여야 한다.

③ 공공시스템운영기관은 제5조제4항에 따른 계정을 발급할 때에는 개인정보 보호 교육을 실시하고, 보안 서약을 받아야 한다.

④ 공공시스템운영기관은 정당한 권한을 가진 개인정보취급자에게만 접근 권한이 부여・관리되고 있는지 확인하기 위하여 제5조제3항에 따른 접근 권한 부여, 변경 또는 말소 내역 등을 반기별 1회 이상 점검하여야 한다.

⑤ 공공시스템에 접속하여 개인정보를 처리하는 기관(이하 "공공시스템이용기관"이라 한다)은 소관 개인정보취급자의 계정 발급 등 접근 권한의 부여・관리를 직접하는 경우 제2항부터 제4항까지의 조치를 하여야 한다.

제17조(공공시스템운영기관의 접속기록의 보관 및 점검) ① 공공시스템 접속기록 등을 자동화된 방식으로 분석하여 불법적인 개인정보 유출 및 오용·남용 시도를 탐지하고 그 사유를 소명하도록 하는 등 필요한 조치를 하여야 한다.

② 공공시스템운영기관은 공공시스템이용기관이 소관 개인정보취급자의 접속기록을 직접 점검할 수 있는 기능을 제공하여야 한다.

제18조(공공시스템운영기관의 취약점 점검 및 조치) ① 공공시스템운영기관은 내부 관리계획에서 정한 취약점 점검을 공공시스템별로 연 1회 이상 실시하여야 한다.

② 공공시스템운영기관은 제1항에 따른 취약점 점검 외에 별도로 외부 전문기관 또는 외부 전문가에 의한 침투 테스트를 공공시스템별로 연 1회 이상 실시하여야 한다.

③ 공공시스템운영기관은 제1항과 제2항에 따른 점검 결과 등에 따라 필요한 보완조치를 지체 없이 시행하여야 한다.

제19조(재검토 기한) 개인정보보호위원회는 「행정규제기본법」 제8조 및 「훈령·예규 등의 발령 및 관리에 관한 규정」에 따라 이 고시에 대하여 2023년 9월 15일을 기준으로 매 3년이 되는 시점(매 3년째의 9월 14일까지를 말한다)마다 그 타당성을 검토하여 개선 등의 조치를 하여야 한다.

부칙 <제2020-2호,2020.8.11.>

이 고시는 고시한 날부터 시행한다.

부칙 <제2021-2호,2021.9.15.>

이 고시는 고시한 날부터 시행한다.

부칙 <제2023-6호,2023.9.22.>

이 고시는 발령한 날부터 시행한다. 다만, 다음 각 호의 개정규정은 각 호의 구분에 해당하는 개인정보처리자에 대해서는 2024년 9월 15일부터 시행한다.

1. 제5조제6항, 제7조제6항, 제8조제2항, 제11조의 개정규정 : 종전의 「(개인정보보호위원회) 개인정보의 기술적·관리적 보호조치 기준」(개인정보보호위원회고시 제2021-3호) 적용대상인 개인정보처리자
2. 제7조제4항, 제12조제2항의 개정규정 및 제5조제6항 중 정보주체에 관한 개정규정 : 종전의 「(개인정보보호위원회) 개인정보의 안전성 확보조치 기준」(개인정보보호위원회고시 제2021-2호) 적용대상인 개인정보처리자
3. 제14조부터 제17조까지의 개정규정 : 공공시스템운영기관과 공공시스템이용기관

부칙 <제2025-9호,2025.10.31.>

제1조(시행일) 이 고시는 발령한 날부터 시행한다. 다만, 제4조제1항 제12호 및 제13호, 제5조제1항 및 제6항, 제6조제2항, 제8조제1항 및 제2항은 발령한 날의 1년 후부터 시행한다.

부칙 <제2026-9호,2026.7.1.>

이 고시는 발령한 날 부터 시행한다. 다만, 제15조제5호 및 제18조는 2027년 1월 1일부터 시행한다.

[별표] 위험을 감소시킬 수 있는 보호조치 예시 (제6조의2 관련)

【별표】 위험을 감소시킬 수 있는 보호조치 예시 (제6조의2 관련)

구분	보호조치 예시
1. 개인정보 파일을 다운로드 할 수 있는 개인정보취급자의 컴퓨터 등	◇ 개인정보처리시스템 접속 시 안전한 인증수단 적용 ◇ 개인정보 파일 저장 시 안전한 암호 알고리즘으로 암호화 ◇ 개인정보 다운로드 건수 제한 ◇ 개인정보 다운로드 권한을 가진 개인정보취급자 최소화 ◇ 개인정보 출력시 마스킹, 안심번호 등 표시제한 조치 적용
2. 개인정보 파일을 파기할 수 있는 개인정보취급자의 컴퓨터 등	◇ 개인정보 파기 권한을 가진 개인정보취급자 최소화 ◇ 개인정보 파기시 관리자 등으로부터 별도 승인을 받도록 설정
※ “예시”는 개인정보처리자가 개인정보에 대한 접근을 통제하기 위해 필요한 조치를 마련하는 과정에서 ‘필요한 조치’에 해당하는지를 판단할 때 적용해야 하는 안전조치 사례로, 실제 사례에서는 구체적 사실관계에 따라 필요한 부분을 선별적으로 적용할 수 있음	